

README – Kit de Encuesta OWASP 2025 – España

Versión 1.0 – Borrador para uso piloto y adaptación institucional

1. ¿Qué es este kit?

Este kit reúne los componentes necesarios para diseñar, ejecutar y explotar una encuesta de madurez en ciberseguridad basada en OWASP, orientada al contexto español y alineada con NIS2 y el Esquema Nacional de Seguridad (ENS).

Está pensado para CISOs, equipos de riesgos, unidades de ciberseguridad institucionales y grupos de investigación que deseen medir el estado real de la seguridad de aplicaciones y de la gobernanza digital en organizaciones públicas y privadas.

2. Contenido del kit

El kit incluye los siguientes archivos en formato Markdown:

1.
encuesta-owasp.md
Modelo de Encuesta Integral con bloques temáticos (perfil, gobernanza, Top 10:2025, SAMM, ASVS, riesgo, cultura, cadena de suministro, operaciones).
2.
guia-metodo.md
Guía metodológica detallada sobre objetivos, población, muestreo, diseño de escalas, cálculo del Índice Global de Madurez (IGM) y aproximación al ROI.
3.
narrativa-explic.md
Narrativa explicativa para acompañar la encuesta (correo de invitación, nota del CISO, texto de introducción en el formulario).
4.
mapeo-preguntas.md
Tabla de mapeo de cada pregunta con marcos OWASP (Top 10, SAMM, ASVS), ámbitos de NIS2 y dominios ENS, y tipo de indicador.
5.
plantilla-igm-roi.md
Descripción de la plantilla de Excel para cálculo del IGM, subíndices y ROI de seguridad.
6.
ppt-ejecutivo.md
Plantilla de reporte ejecutivo en forma de estructura de presentación (PowerPoint o equivalente) para comunicar resultados a la alta dirección y a reguladores.

encuesta-owasp.md

Modelo de **Encuesta Integral** con bloques temáticos (perfil, gobernanza, Top 10:2025, SAMM, ASVS, riesgo, cultura, cadena de suministro, operaciones).

guia-metodo.md

Guía metodológica detallada sobre objetivos, población, muestreo, diseño de escalas, cálculo del Índice Global de Madurez (IGM) y aproximación al ROI.

narrativa-explic.md

Narrativa explicativa para acompañar la encuesta (correo de invitación, nota del CISO, texto de introducción en el formulario).

mapeo-preguntas.md

Tabla de mapeo de cada pregunta con marcos OWASP (Top 10, SAMM, ASVS), ámbitos de NIS2 y dominios ENS, y tipo de indicador.

plantilla-igm-roi.md

Descripción de la **plantilla de Excel** para cálculo del IGM, subíndices y ROI de seguridad.

ppt-ejecutivo.md

Plantilla de reporte ejecutivo en forma de estructura de presentación (PowerPoint o equivalente) para comunicar resultados a la alta dirección y a reguladores.

3. Cómo usar el kit (modo rápido)

7.
Personalizar la encuesta
Abra encuesta-owasp.md, revise los bloques y adapte terminología y ejemplos a su sector (por ejemplo, salud, energía, banca, administración pública).
8.
Diseñar el formulario
Implemente la encuesta en su herramienta preferida (formularios web, plataforma de encuestas, etc.), manteniendo los IDs de preguntas (P2.1, P3.5, etc.) para conservar la trazabilidad.
9.
Definir la metodología
Revise guia-metodo.md para validar el enfoque de población, muestreo y cálculo de índices. Ajuste ponderaciones y variables a su contexto.
10.
Invitar a participantes
Utilice narrativa-explic.md como base para el correo de invitación y la página de presentación de la encuesta.
11.
Mapear a obligaciones regulatorias
Considere mapeo-preguntas.md cuando deba explicar a auditores o reguladores cómo la encuesta se alinea con NIS2 y ENS.
12.
Implementar la analítica
Use plantilla-igm-roi.md para construir la hoja de cálculo que transformará respuestas en indicadores (IGM, subíndices, ROI aproximado).
13.
Presentar resultados
Siga la estructura de ppt-ejecutivo.md para diseñar una presentación clara, comprensible y accionable para la alta dirección.

Personalizar la encuesta

Abra encuesta-owasp.md, revise los bloques y adapte terminología y ejemplos a su sector (por ejemplo, salud, energía, banca, administración pública).

Diseñar el formulario

Implemente la encuesta en su herramienta preferida (formularios web, plataforma de encuestas, etc.), manteniendo los IDs de preguntas (P2.1, P3.5, etc.) para conservar la trazabilidad.

Definir la metodología

Revise `guia-metodo.md` para validar el enfoque de población, muestreo y cálculo de índices. Ajuste ponderaciones y variables a su contexto.

Invitar a participantes

Utilice `narrativa-explic.md` como base para el correo de invitación y la página de presentación de la encuesta.

Mapear a obligaciones regulatorias

Considere `mapeo-preguntas.md` cuando deba explicar a auditores o reguladores cómo la encuesta se alinea con NIS2 y ENS.

Implementar la analítica

Use `plantilla-igm-roi.md` para construir la hoja de cálculo que transformará respuestas en indicadores (IGM, subíndices, ROI aproximado).

Presentar resultados

Siga la estructura de `ppt-ejecutivo.md` para diseñar una presentación clara, comprensible y accionable para la alta dirección.

4. Niveles de personalización

Este kit es deliberadamente genérico pero no neutral; asume un contexto español, marcos OWASP, NIS2 y ENS. Se recomienda personalizar en tres niveles:

14. Nivel terminológico

15.

Adaptar nombres de órganos, roles y referencias internas (por ejemplo, comités, unidades organizativas).

16.

Nivel sectorial

17.

Añadir bloques o preguntas específicas (por ejemplo, escenarios clínicos en salud, sistemas SCADA en energía).

18.

Nivel analítico

19. Ajustar ponderaciones del IGM, umbrales de interpretación y modelo de ROI a la realidad y apetito de riesgo de su organización.

Adaptar nombres de órganos, roles y referencias internas (por ejemplo, comités, unidades organizativas).

Nivel sectorial

Añadir bloques o preguntas específicas (por ejemplo, escenarios clínicos en salud, sistemas SCADA en energía).

Nivel analítico

5. Prerrequisitos recomendados

- Un equipo impulsor con representación de:
- Ciberseguridad / CISO.
- Riesgos / cumplimiento.
- Desarrollo / DevSecOps.
-
- Negocio / dirección.
-
- Herramientas básicas:
- Plataforma de encuestas o formularios.
-
- Hoja de cálculo (Excel, LibreOffice, Google Sheets, etc.).
-
- Apetito mínimo de autoconocimiento: ganas de ver la foto real, aunque algunos píxeles salgan movidos.

Negocio / dirección.

Herramientas básicas:

Hoja de cálculo (Excel, LibreOffice, Google Sheets, etc.).

Apetito mínimo de autoconocimiento: ganas de ver la foto real, aunque algunos píxeles salgan movidos.

6. Buenas prácticas de despliegue

- Empezar con un piloto controlado en un grupo reducido de organizaciones para ajustar preguntas y tiempos.
- Promover la participación multiactor dentro de cada entidad (no dejar toda la carga al CISO).
- Ofrecer retornos de valor claros a las organizaciones (informes comparativos, recomendaciones, talleres).
- Revisar periódicamente el cuestionario para alinearlo con nuevas versiones de OWASP, cambios en NIS2/ENS y lecciones aprendidas.

7. Limitaciones y avisos necesarios

- Este kit no sustituye asesoramiento jurídico ni técnico específico; es una herramienta de diagnóstico y apoyo estratégico.
- Las métricas propuestas (IGM, ROI aproximado) dependen de la calidad de los datos y de los supuestos realizados.
- El uso de OWASP, NIS2 y ENS como marcos de referencia no implica una certificación automática; más bien ofrece un lenguaje común entre técnicos, gestores y reguladores.

8. Próximos pasos sugeridos

20. Designar un equipo responsable del proyecto de encuesta dentro de su organización o institución.
21. Definir un calendario de despliegue (piloto, primera ola, siguiente revisión).
22. Establecer desde el principio cómo se compartirán y utilizarán los resultados (informes internos, comunicación a órganos de gobierno, contribución a observatorios nacionales, etc.).

Este README es la puerta de entrada; el resto del kit es la caja de herramientas. La obra, como siempre, queda en sus manos.